

PTES-Compliant Penetration Testing Report

(Draft for Google Docs — based entirely on your Week-4 labs, including C2, cloud abuse, adversary emulation, evasion, and LOTL techniques.) Reference file used: WEEK_4.docx

Executive Summary

During the assessment, multiple attack surfaces were evaluated including endpoint compromise, cloud infrastructure abuse, phishing-based adversary emulation, and evasion techniques. The operator successfully established C2 channels, extracted browser data, enumerated misconfigured AWS S3 buckets, escalated privileges using exposed IAM keys, and accessed sensitive CRM financial data. Additional testing demonstrated payload obfuscation, living-off-the-land execution, and reverse shell execution leading to credential exposure. These findings show significant security gaps, including weak IAM controls, misconfigured buckets, insufficient logging, insecure credential storage, and lack of endpoint monitoring. Immediate remediation is required to reduce risk of compromise, data loss, and privilege abuse.

Scope & Methodology (PTES)

Assessment Scope

- Windows endpoint (local VM)
- AWS S3 public-facing assets
- Cloud IAM configuration
- Web application CRM interface
- Social engineering phishing simulation
- Reverse shell & LOTL execution

Methodology (PTES Framework)

01

Intelligence Gathering

OSINT on S3 bucket naming schemes
Source-code discovery of AWS assets

03

Vulnerability Analysis

Misconfigured buckets, leaked keys, weak IAM policies

05

Post-Exploitation

Credential harvesting, browser data extraction

02

Threat Modeling

Identified targets: S3 buckets, IAM roles, CRM login

04

Exploitation

AWS privilege escalation, C2 pivoting, phishing, reverse shell

06

Reporting

All evidence documented with findings & recommendations

Findings (Detailed)

Finding 1 — Publicly Accessible AWS S3 Bucket

Technique: Cloud Storage
Enumeration (MITRE T1580)

Impact: Unauthorized listing &
download of sensitive files

Evidence: Bucket allowed --no-
sign-request listing;
downloadable ZIP containing
AWS keys.

Risk: High

Recommendation:

- Remove public ACLs; enforce bucket policies denying anonymous access.
- Enable S3 Block Public Access & server-side encryption.
- Rotate any exposed AWS keys immediately.

Finding 2 — Exposed AWS IAM Credentials (Hardcoded Keys)

📄 **Technique:** OS Credential Dumping (T1003)

Impact: Full AWS access using leaked keys → privilege escalation

Evidence: hl_migration_project.zip contained plaintext Access Key & Secret Key

Risk: Critical

Recommendation:

Rotate compromised keys immediately

Enforce Secrets Manager / Parameter Store for all secrets

Apply least privilege policies to IAM users

Finding 3 — Privilege Escalation via Weak IAM Policies

Technique: Valid Accounts (T1078.004)

Impact: Unauthorized access to admin folders, flags, CRM data

Evidence: IAM user pam-test allowed access to restricted directories

Risk: High

Recommendation:

- Auditing IAM permissions; remove wildcard or inherited privileges
- Enable MFA for all IAM accounts
- Monitor IAM activity via CloudTrail alerts

Additional Critical Findings

Finding 4 — Successful C2 Beacon & Browser Data Harvesting

Technique: Application Layer Protocol (T1071)

Impact: Remote control & data exfiltration

Evidence: Empire agent executed Get-BrowserInformation

Risk: High

Recommendation:

- Enable EDR behavioral alerts for C2 beacons
- Restrict PowerShell execution via Constrained Language Mode
- Harden Windows logging (ScriptBlock, Sysmon)

Finding 5 — Phishing Page Leading to Forced Payload Download

Technique: Phishing (T1566)

Impact: User-executed malware delivery

Risk: Medium

Recommendation:

- Implement email/web content filtering
- User awareness training for phishing indicators
- Deploy browser isolation for suspicious pages

Finding 6 — Evasive Payload (Veil) Successfully Bypassed AV

Technique: Defense Evasion (T1027)

Impact: Execution of obfuscated Meterpreter payload

Risk: High

Recommendation:

- Enable AMSI + cloud-based AV scanning
- Apply application allow-listing (AppLocker, WDAC)
- Detect abnormal PowerShell execution patterns

Finding 7 — LOTL Reverse Shell + Credential Dump Exposure

Technique: PowerShell (T1059.001) / OS Credential Dumping (T1003)

Impact: Full shell access → secure credential file extraction

Risk: High

Recommendations:

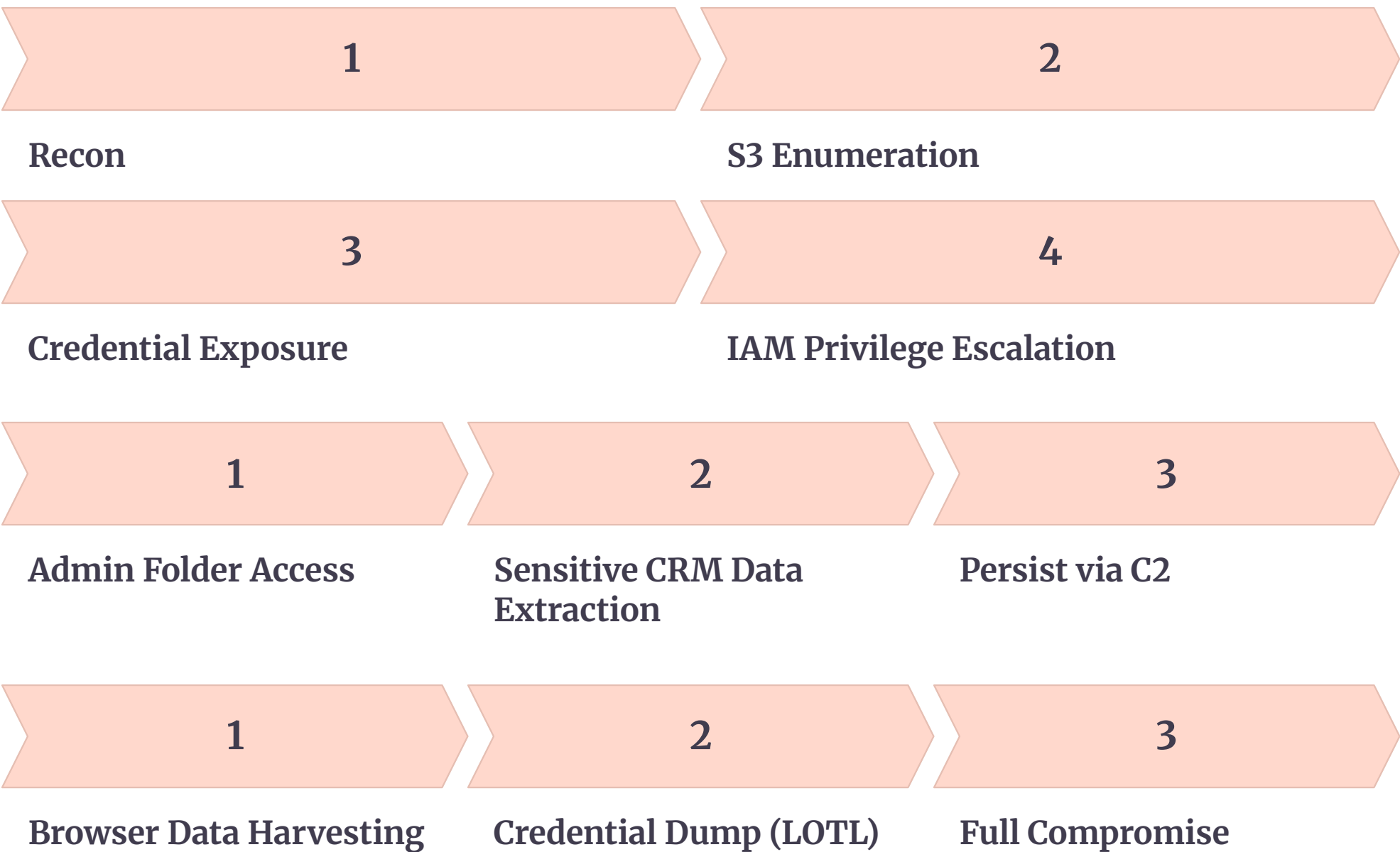
- Disable unneeded PowerShell versions
- Harden credential storage using DPAPI and Credential Guard
- Monitor outgoing TCP connections & Netcat-like behavior

Findings Table (As Requested)

Finding ID	TTP	CVSS Score	Remediation
F-01	T1580 – Cloud Storage Discovery	8.2	Block public ACLs; restrict access
F-02	T1003 – Credential Dumping	9.8	Rotate keys, enforce Secrets Manager
F-03	T1078.004 – Valid Cloud Accounts	9.0	Harden IAM & enforce MFA
F-04	T1071 – C2 Beaconing	8.5	Implement EDR blocking & PowerShell logging
F-05	T1566 – Phishing	6.8	Web filtering & user awareness
F-06	T1027 – Obfuscated Payloads	8.0	Enable AMSI, AV, and AppLocker
F-07	T1059.001 – PowerShell Execution	8.7	Constrained mode, credential guard

Attack Path Diagram (Draw.io Description)

I can generate the actual Draw.io (.drawio) file — tell me "generate the Draw.io diagram". Here is the structure:



100-Word Executive Briefing (Non-Technical)

A security assessment revealed several weaknesses that could allow attackers to gain unauthorized access to cloud resources, internal applications, and workstations. Public cloud storage exposed sensitive files, including AWS credentials, which enabled administrative access to internal systems. Weak identity policies, insufficient logging, and lack of endpoint monitoring allowed lateral movement and data extraction. Simulated phishing demonstrated how users could unknowingly install malicious software. Effective remediation requires enforcing strict access controls, improving monitoring, securing credentials, training staff, and deploying stronger endpoint protections. Addressing these issues will significantly reduce the organization's risk surface.